

PROCURE-TO-PAY PLATFORM

ProcureFlow

Platform, Security & Compliance Dossier

Capability, control and compliance reference for evaluators

A complete technical and control reference for evaluators: what the platform does, how tenant data is isolated, which certifications apply and on what basis, and where the roadmap stands. **Prepared for procurement, finance and information-security review.**

DOCUMENT	Platform, Security & Compliance Dossier
PRODUCT	ProcureFlow — multi-tenant procure-to-pay suite
VERSION	2.0
ISSUED	30 July 2026
CLASSIFICATION	Public — may be shared with prospective clients
HOSTING PLATFORM	Zoho Catalyst (serverless)
PUBLISHER	Cloud Partners
CONTACT	sulaiman@cloudpartners.biz
REVIEW CYCLE	Annual, or upon material platform change

Contents

Seven sections. Roadmap items are marked in place and carry no delivery commitment.

- | | |
|----|---|
| 01 | Executive Summary
What ProcureFlow is, who it serves, and what a buyer is committing to |
| 02 | Functional Modules
The application surface available to an operating tenant |
| 03 | Security Architecture
Controls implemented in the platform, at assessor-level specificity |
| 04 | Certifications & Compliance
Stated precisely, with the basis for each claim identified |
| 05 | Configuration Model
How one platform serves different industries without forking the codebase |
| 06 | Support & Operations
The service wrapped around the software |
| 07 | Technical Specification
For infrastructure and architecture review |

HOW TO READ THIS DOCUMENT

Capability marks are used consistently throughout. **Core** denotes a foundational module that is always active. **Live** denotes a feature implemented and in production. **Optional** denotes a capability that exists but is disabled by default and enabled per tenant. **Roadmap** denotes work that is planned and not yet available.

Nothing marked Roadmap should be relied upon in a procurement decision.

01 Executive Summary

What ProcureFlow is, who it serves, and what a buyer is committing to.

ProcureFlow is a multi-tenant procure-to-pay platform covering the full commercial cycle: purchase requests, multi-level approvals, competitive bidding, purchase orders, goods receipt, three-way invoice matching, budget control, payments and supplier management. Every organisation operates in an isolated tenant with its own users, master data, budgets, documents and audit trail.

The platform is delivered as a single codebase serving every client. Differences between customers are expressed as configuration, not custom builds — through a capability registry, industry packs and per-tenant overrides described in Section 5. This is deliberate: it means a client receives security patches and improvements on the same schedule as every other client, with no forked branch left behind on an old release.

AT A GLANCE

ATTRIBUTE	POSITION
Deployment model	Multi-tenant SaaS, serverless on Zoho Catalyst
Functional modules	17 application modules + supplier portal + administration console
Configurable capabilities	26, resolved per tenant across three precedence layers
Industry packs	6 — hospitality, manufacturing, healthcare, construction, retail, general
Data model	39 tenant-scoped tables, schema-validated on every write
Authentication	Zoho Catalyst hosted identity; server-side session validation
Access control	Role- and profile-based, enforced server-side per module and action
Audit	Immutable append-only log of business and support actions
Integration	Zoho Books (OAuth 2.0), outbound workflow webhooks

02 Functional Modules

The application surface available to an operating tenant.

2.1 The procure-to-pay chain

The core cycle is a controlled sequence. Each stage validates against the one before it, so value cannot enter the ledger without a documented origin.

01 Request Requester raises a PR against a department budget	02 Approve Routed by value through approval limits	03 Source Optional RFQ; vendors bid, buyer awards	04 Order PO issued to the awarded supplier	05 Receive GRN records what physically arrived	06 Match Bill matched to PO and receipt	07 Pay Payment settles budget commitment
--	--	---	--	--	---	--

2.2 Module reference

MODULE	FUNCTION	STATUS
Purchase Requests	Requisition entry, itemised lines, justification, budget check at submission	CORE
Approvals	Value-banded routing, per-user approval limits, escalation and fallback approver	CORE
Request for Quotes	Publish to selected vendors, collect sealed bids, award with automatic line repricing	LIVE
Purchase Orders	Formal orders, terms, delivery detail, supplier acknowledgement	CORE
Purchase Receives	Goods receipt notes with accepted and rejected quantities per line	LIVE
Bills	Supplier invoices with automatic three-way match and discrepancy scoring	CORE
Recurring Bills	Scheduled obligations — rent, retainers, subscriptions	LIVE
Payments Made	Full and partial settlement, overpayment prevention, mode and reference capture	LIVE
Vendor Credits	Credit notes offset against future payables	LIVE
Budgets	Allocation, commitment and settlement per department and fiscal year	LIVE
Items	Catalogue with SKU, pricing, category, unit, preferred vendor, CapEx/OpEx class	CORE
Vendors	Supplier master with contacts, bank details, rating and compliance status	CORE
Vendor Portal	External supplier access — view RFQs, submit bids, acknowledge orders, track bills	LIVE
Properties & Sites	Per-site budgets, requests and reporting for multi-location operators	OPTIONAL
Asset Register	Capitalised assets created from received CapEx purchases	OPTIONAL
Custom Modules	Tenant-defined record types beyond the built-in set	LIVE
Reports & Dashboards	Role-scoped dashboards with configurable widgets	LIVE

2.3 Financial controls

Budget enforcement operates on a three-part ledger. Allocated funds are reduced by committed value the moment a request is approved, and committed value converts to spent only when a bill is settled. This prevents the common failure where a department appears solvent because approved-but-unbilled orders are invisible.

CONTROL	BEHAVIOUR
Budget blocking	Submissions exceeding remaining budget are rejected at source, not flagged after the fact
Three-way matching	Bill reconciled against PO and goods receipt; variance scored and surfaced before payment authorisation
Overpayment prevention	Cumulative payments cannot exceed bill value; enforced server-side
Segregation of duties	Request, approval, receipt and payment are distinct permissioned actions
CapEx / OpEx	Classification carried from catalogue item through to the settled bill
Per-site scoping	Where multi-site is enabled, budgets commit and release against the originating site

03 Security Architecture

Controls implemented in the platform, stated at the level of specificity an assessor requires.

3.1 Identity and authentication

Authentication is delegated to Zoho Catalyst hosted identity. ProcureFlow does not store, hash or transmit end-user passwords, which removes an entire class of credential-handling risk from the application boundary.

Every request is validated server-side against a user-scoped session. The validation is deliberately strict: the server refuses to fall back to a platform-administrative credential when no genuine user session is present, so an unauthenticated request fails closed rather than executing with elevated rights.

3.2 Tenant isolation

DESIGN PRINCIPLE

Tenant context is derived from the authenticated user's own membership records — never from a client-supplied value. Where a request nominates an organisation, that value can only select among organisations the user already belongs to. It cannot grant access to any other tenant.

CONTROL	IMPLEMENTATION
Scope derivation	Organisation resolved from server-side membership lookup on every request
Query scoping	Tenant-owned records filtered by organisation identifier at the data layer
Cross-tenant attempt	Rejected with an explicit authorisation failure and logged
Object storage	Files partitioned per organisation under a tenant-scoped prefix
Suspension	Suspended tenants are refused at the middleware boundary before business logic runs

3.3 Authorisation

Access control combines roles (organisational position) with profiles (permission sets), evaluated per module and per action — create, read, edit, delete. Enforcement is server-side on every protected endpoint. Interface elements are hidden from users without rights, but that concealment is a usability measure and never the control itself; a request forged past the interface is still refused by the server.

3.4 Data protection

CONTROL	IMPLEMENTATION
In transit	TLS enforced platform-wide; application served over HTTPS only
At rest	Encryption provided by the Zoho Catalyst data and object storage layers
Query construction	All user-supplied values escaped before query composition, preventing injection
Write validation	Every write is validated against the authoritative schema for its table; unrecognised fields are stripped and logged rather than persisted
Cross-origin policy	Requests accepted only from an explicit allow-list of platform domains
Secret handling	Integration credentials held server-side; never transmitted to the browser

3.5 Supplier portal security

Suppliers are external parties and are treated as such. Portal access uses a separate credential path from internal users, with no ability to traverse into the buying organisation's internal records.

CONTROL	IMPLEMENTATION
Access codes	Stored only as SHA-256 digests; never retained in plaintext
Session tokens	Cryptographically random; stored as digests, so a database disclosure yields no usable session
Invitation validity	Invite links expire after 7 days and are single-use
Session validity	Sessions expire after 30 days; expired sessions are purged automatically
Scope	A supplier session resolves to exactly one organisation and one vendor record

3.6 Audit and accountability

Business events are written to an append-only audit log capturing the actor, action, record type, record identifier, detail payload and timestamp. Support actions performed by the platform team are logged to the same trail and are distinguishable from tenant-user activity, so a client can always establish who did what — including when the actor was the vendor's own support staff.

DISCLOSED LIMITATION

Support impersonation sessions are logged, time-limited to 30 minutes and surfaced to the tenant with an on-screen banner, but are not currently enforced as read-only at the server.

Clients requiring a hard read-only guarantee for vendor support access should raise this during contracting. Remediation is on the roadmap and is disclosed here rather than omitted.

04 Certifications & Compliance

Stated precisely, with the basis for each claim identified.

BASIS OF THESE STATEMENTS

ProcureFlow is built on Zoho Catalyst and inherits the certified controls of that platform for infrastructure, physical security, encryption and operational resilience. Those certifications are held by Zoho Corporation and are independently verifiable.

Certifications held by ProcureFlow as an application in its own right are listed separately and honestly. This document does not claim an audit that has not taken place.

4.1 Inherited platform certifications

Applicable to the hosting infrastructure on which ProcureFlow runs. Held by Zoho Corporation — verifiable at zoho.com/security.

STANDARD	COVERAGE	HELD BY
ISO/IEC 27001	Information security management system	Zoho
ISO/IEC 27017	Cloud-services information security controls	Zoho
ISO/IEC 27018	Protection of personal data in public cloud	Zoho
SOC 2 Type II	Security, availability and confidentiality controls	Zoho
GDPR	EU data protection; data-processing terms available	Zoho
Data residency	Regional hosting across multiple data-centre regions	Zoho

4.2 ProcureFlow application posture

Application-level status, stated without inference from platform certification.

ITEM	STATUS	MARK
Tenant isolation controls	Implemented and enforced server-side	LIVE
Role- and profile-based access control	Implemented and enforced server-side	LIVE
Audit trail	Append-only, covering business and support actions	LIVE
Encryption in transit and at rest	Provided by the platform layer	LIVE
Segregation of duties	Enforced across the procure-to-pay chain	LIVE
Independent penetration test	Not yet commissioned	ROADMAP
SOC 2 Type II for ProcureFlow as an application	Not held; infrastructure controls inherited from Zoho	ROADMAP
ISO 27001 for the publishing entity	Not held	ROADMAP
Read-only enforcement on support impersonation	Logged and time-limited; not yet enforced server-side	ROADMAP

4.3 Data protection commitments

COMMITMENT	POSITION
Data ownership	The client owns its data at all times. ProcureFlow acts as processor.

COMMITMENT	POSITION
Data export	Tenant data is exportable in structured form on request and at termination.
Deletion	On termination, tenant records and stored objects are removed on request.
Secondary use	Client data is never used to train models or sold to third parties.
Sub-processors	Zoho Corporation is the sole infrastructure sub-processor.
Breach notification	Clients notified without undue delay; terms fixed in the service agreement.

05 Configuration Model

How one platform serves different industries without forking the codebase.

Client-specific behaviour is resolved through three ordered layers. A later layer overrides an earlier one, and certain capabilities are locked so they can never be switched off — the procure-to-pay chain cannot be disabled into an inconsistent state.

LAYER 1 Registry default Platform-wide baseline for each capability	LAYER 2 Industry pack Sector defaults, terminology, departments, categories	LAYER 3 Tenant override Per-client adjustment, applied without a release
---	---	--

WHY THIS MATTERS COMMERCIALY

Because customisation is configuration rather than code, a client's requirements never place them on a private branch. Every tenant runs the same audited release and receives security fixes simultaneously. Configuration changes take effect without a deployment and without downtime.

5.1 Industry packs

PACK	SECTOR-SPECIFIC CAPABILITY EMPHASIS
Hotel Management & Hospitality	Multi-property budgets and reporting, batch and expiry tracking, supplier compliance documents
Manufacturing & Production	Bill of materials, landed cost apportionment, multi-site operations
Healthcare & Pharmaceuticals	Batch and expiry control, supplier certification tracking and expiry
Construction & Real Estate	Project and job costing, asset register, multi-site scoping
Retail & Distribution	Multi-outlet budgets, landed cost, high-volume catalogue handling
General Business	Balanced default configuration for cross-sector use

5.2 Configurable capabilities

26 capabilities across six control groups. Capabilities marked LOCKED are structural to the procure-to-pay chain and cannot be disabled.

GROUP	CAPABILITIES
Procurement	Purchase requests · LOCKED · RFQs · Purchase orders · LOCKED · Goods receipt
Payables	Bills · LOCKED · Three-way matching · Recurring bills · Vendor credits · Partial payments
Financial control	Budgets · Over-budget blocking · Multi-currency · CapEx/OpEx classification
Structure	Multi-property · Asset register · Departments
Collaboration	Vendor portal · Custom modules · Custom fields · Workflow webhooks · Zoho Books integration
Industry	Batch & expiry · Landed cost · Bill of materials · Project costing · Compliance documents

5.3 Tenant-level extensibility

Where configuration is not enough, a tenant administrator can extend the platform within controlled boundaries — without engineering involvement and without leaving the shared release.

EXTENSION POINT	WHAT A TENANT ADMINISTRATOR CAN DO
Custom fields	Additional fields on native modules, defined by the tenant administrator
Custom modules	Entirely new record types with a tenant-defined schema
Document templates	Configurable layouts for purchase orders and other issued documents
Dashboards	Widget configurations scoped by role and profile
Workflow webhooks	Outbound event notifications to external systems on record change

06 Support & Operations

The service wrapped around the software.

6.1 Support tiers

TIER	SCOPE	HANDLED BY
L1	Usage questions, configuration guidance, account and access issues	Client administrator / support desk
L2	Configuration correction, data investigation, capability adjustment	Platform support
L3	Defect diagnosis and resolution, tenant repair, engineering escalation	Engineering

6.2 Severity definitions

SEVERITY	DEFINITION
S1 — Critical	Service unavailable or financial data integrity at risk; no workaround
S2 — High	Major function unavailable; workaround exists but is materially disruptive
S3 — Normal	Function impaired with an acceptable workaround
S4 — Low	Cosmetic issue, question or enhancement request

ON RESPONSE TARGETS

Response and resolution targets are fixed in the service agreement, not in this document. Targets stated in a marketing document are not contractual — ask for them in the SLA.

6.3 Operational tooling

The platform team operates a dedicated administration console providing tenant health scoring, configuration inspection and repair, capability management, a support case log and audited impersonation. All actions taken through this console are written to the tenant's audit trail, so vendor activity is visible to the client rather than occurring silently.

6.4 Enhancement handling

Client-specific requirements are triaged into one of four mechanisms, in order of preference: capability flag, configuration data, industry pack extension, or extensibility feature. Where a genuinely novel requirement arrives, it is built as a new capability available to all tenants and enabled for the requesting client. The platform does not maintain per-client code forks.

07 Technical Specification

For infrastructure and architecture review.

COMPONENT	SPECIFICATION
Hosting	Zoho Catalyst — serverless, managed scaling
Application runtime	Node.js 20, Express-style routing
Data store	Catalyst Data Store, 39 tables, schema-validated writes
Object storage	Catalyst Stratus, tenant-partitioned by prefix
Client application	Progressive web application; no installation required
Browser support	Current versions of Chrome, Edge, Safari and Firefox
Accessibility	Responsive layout, keyboard navigation, light and dark themes
Integration — accounting	Zoho Books via OAuth 2.0; bill and payment synchronisation
Integration — outbound	Workflow webhooks on business events
Availability	Inherits Zoho Catalyst platform availability
Backup and recovery	Provided by the Catalyst platform data layer

7.1 Onboarding sequence

01 Provision Tenant created, industry pack applied	02 Verify Organisation verified by the platform team	03 Configure Departments, roles, profiles, approval limits	04 Load Catalogue, vendors and budgets imported	05 Operate Users invited; first cycle transacted
--	--	--	---	--

7.2 Evaluation checklist

Questions a thorough evaluator should ask, with where the answer sits.

QUESTION	REFERENCE
How is my data separated from other clients?	Section 3.2
Who at the vendor can see my data, and is it logged?	Sections 3.6 and 6.3
Which certifications are the vendor's own?	Section 4.2
Can I get my data out if we leave?	Section 4.3
Will my customisations delay my security patches?	Section 5
What are the actual response times?	Service agreement — not this document

STATEMENT OF ACCURACY

The capabilities and controls described in this document reflect the platform as built at the issue date. Items not yet implemented are marked Roadmap and carry no delivery commitment. Where a control has a known limitation, it is disclosed in place rather than omitted.

Contractual commitments are established solely in the executed service agreement.

ProcureFlow

PLATFORM, SECURITY & COMPLIANCE DOSSIER

Version 2.0 · Issued 30 July 2026 · Review cycle: annual

Cloud Partners · sulaiman@cloudpartners.biz

Classification: Public — may be shared with prospective clients